

# SF-EDGE Security and Compliance Requirements

Document ID: SF-EDGE-SEC-003

Version: 1.0

Date: 2026-04-25

Owner: Cybersecurity Team

Project: Smart Factory Edge Gateway

## 1. Security Goals

The gateway is deployed inside industrial networks and may have access to production data. Security requirements focus on protecting configuration integrity, limiting remote access, and preventing accidental disclosure of sensitive information.

## 2. Authentication

### SEC-REQ-001 Authenticated API Access

All API endpoints except `/health/live` shall require authentication.

Unauthenticated requests shall return 401 Unauthorized.

### SEC-REQ-002 Session Expiration

User sessions shall expire after 30 minutes of inactivity.

Refresh tokens shall be rotated after each successful refresh.

### SEC-REQ-003 Failed Login Protection

After 5 failed login attempts within 10 minutes, the account shall be locked for 15 minutes.

All failed login attempts shall be written to the audit log.

## 3. Authorization

### SEC-REQ-010 Role-Based Access Control

The system shall enforce role-based access control for all privileged operations.

Role permissions:

- `plant_operator`: read device status and acknowledge alerts;
- `maintenance_engineer`: register devices and edit signal maps;
- `site_admin`: manage users, certificates, rollback, and support grants;
- `cloud_support_engineer`: read diagnostic bundle only with temporary grant.

### SEC-REQ-011 Support Grant

A site administrator may create a temporary support grant for a cloud support engineer.

The grant shall:

- expire automatically after a maximum of 4 hours;
- be revocable before expiration;
- be logged in the audit log;
- restrict access to diagnostic data only.

## 4. Secrets and Certificates

### SEC-REQ-020 Secret Storage

API tokens, private keys, and cloud credentials shall not be stored in plain text.

Secrets shall be encrypted at rest using a device-specific key.

### SEC-REQ-021 Diagnostic Redaction

Diagnostic bundles shall redact:

- passwords;
- API tokens;
- private keys;
- bearer tokens;
- cloud endpoint credentials.

The redaction process shall be tested using known secret patterns.

### SEC-REQ-022 Certificate Expiration Alert

The gateway shall raise an alert when a certificate expires in less than 14 days.

Certificate expiration status shall be visible to the site administrator.

## 5. Audit Logging

### SEC-REQ-030 Audit Event Retention

Audit events shall be retained for at least 180 days.

Audit logs shall not be editable by normal users.

### SEC-REQ-031 Required Audit Events

The following events shall be audited:

- successful login;
- failed login;
- logout;
- device registration;
- device update;
- device deletion or disablement;
- signal map update;
- user role update;
- certificate update;
- diagnostic bundle export;
- configuration rollback;
- support grant creation;
- support grant revocation.

### SEC-REQ-032 Audit Event Fields

Each audit event shall contain:

- audit\_event\_id;
- actor\_user\_id;
- action;
- target\_type;
- target\_id;
- timestamp;

- source\_ip;
- result;
- metadata.

## 6. Network Security

### SEC-REQ-040 TLS

Remote API access shall use TLS 1.2 or higher.

Plain HTTP remote access shall be disabled by default.

### SEC-REQ-041 Local Network Restrictions

The gateway shall allow administrators to restrict API access to configured network ranges.

### SEC-REQ-042 Cloud Endpoint Validation

The Cloud Forwarder shall validate the cloud endpoint certificate chain before sending telemetry.

If certificate validation fails, telemetry shall remain buffered locally.

## 7. Data Protection

### SEC-REQ-050 Minimal Data Exposure

The API shall not expose raw secrets or private keys in any response.

### SEC-REQ-051 Diagnostic Bundle Scope

Diagnostic bundles shall include operational information but shall exclude raw telemetry payloads by default.

The site administrator may explicitly include telemetry samples if needed.

### SEC-REQ-052 Export Logging

Every export operation shall create an audit event with the export type, actor, timestamp, and file checksum.

## 8. Compliance Notes

SF-EDGE is not intended to be a regulated medical or financial system.

However, the gateway may be deployed in environments requiring internal cybersecurity reviews. Therefore, evidence should be available for:

- authentication tests;
- authorization tests;
- redaction tests;
- audit trail tests;
- TLS configuration tests;
- support grant lifecycle tests.

## 9. Security Test Priorities

High-priority security tests:

1. unauthorized API access is rejected;
2. maintenance engineer cannot manage users;
3. plant operator cannot update device configuration;
4. diagnostic bundle redacts secrets;
5. failed login lockout works;

6. support grants expire automatically;
7. cloud forwarding stops when TLS validation fails but local buffering continues.